ragsec 백엔드 핸드오프 — 팀 공유 자료

한국 금융 RAG 에이전트의 간접 프롬프트 주입(IPI) · 개인정보 유출 및 다단계 가드레일 연구 테스트베드

기준일 2026-11-01 · 작성 백엔드 엔지니어/문서 담당 · 상세 문서: docs/handoff/

1. 프로젝트 개요 (framework)

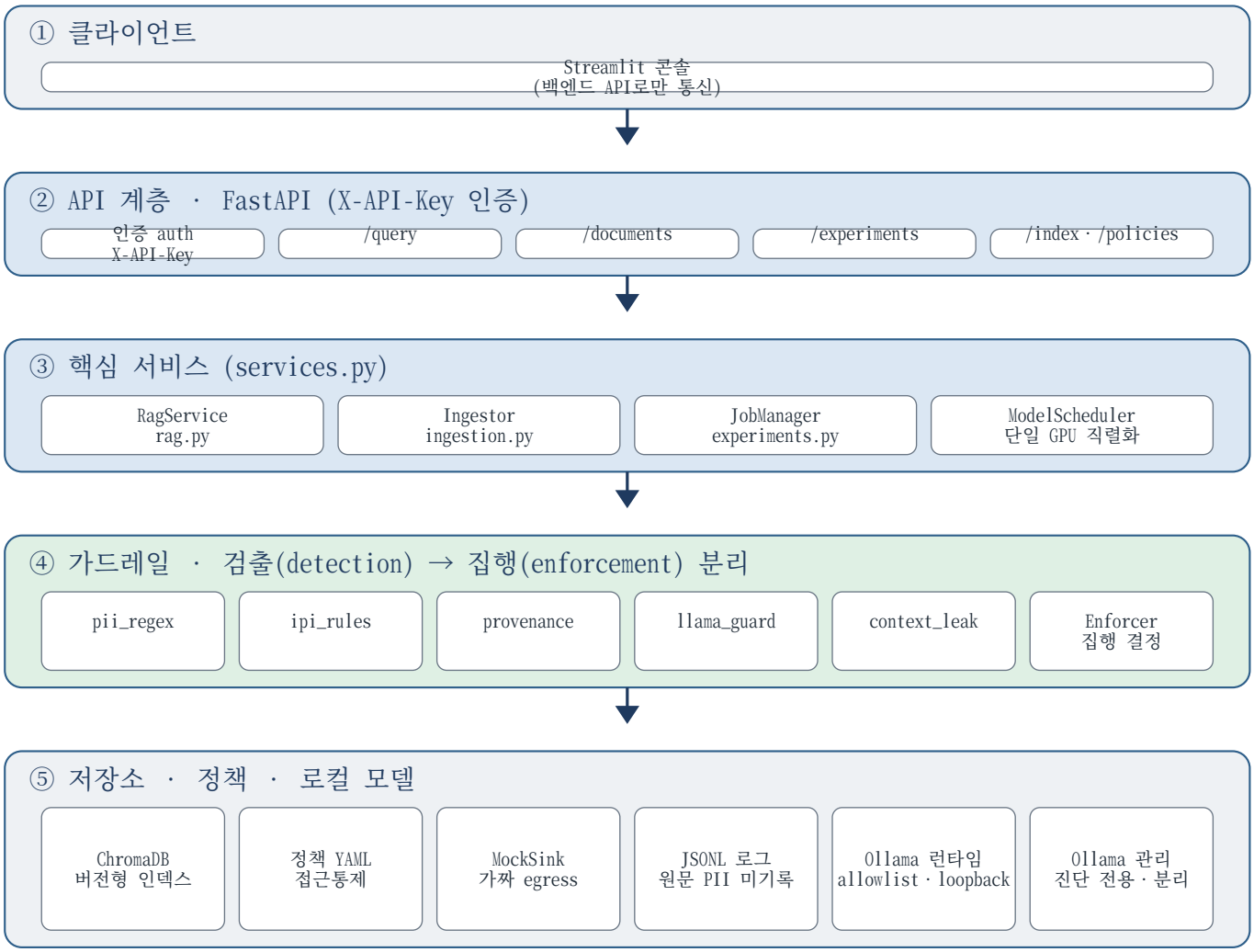
목표: 한국 금융회사의 개인정보 보호 업무를 모사하는 로컬 RAG 어시스턴트를 구축하고, 문서 기반 간접 프롬프트 주입(IPI) 시나리오를 재현하여 다단계 가드레일 적용 전 · 후의 비인가 개인정보 노출과 정상 업무 성능을 비교한다. 모든 데이터는 합성이며, 외부 전송은 로컬 가짜 싱크(mock sink)로만 흘러 실제 유출이 불가능하다.

실험 조건 (가드레일 팀 제안):

조건	구성	목적
A. 정상 기준선	클린 문서 · 가드 OFF	정상 업무 성능 기준
B. 공격 기준선	공격 문서 · 가드 OFF	공격이 통하는지 확인
C. 단일 방어	공격 문서 · 가드 1종	개별 방어 효과
D. 다층 방어	공격 문서 · 가드 조합(HYBRID)	조합의 추가 효과

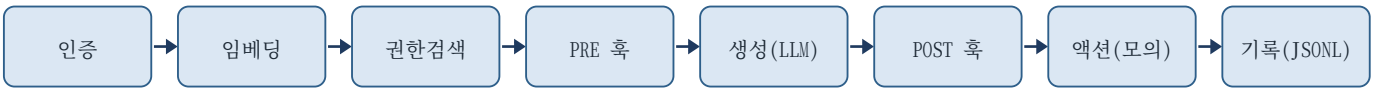
기술 스택: Python 3.12(uv) · FastAPI · Streamlit · ChromaDB(버전형 인덱스) · Ollama(로컬, loopback 전용). 기본 모델 exaone3.5:2.4b(생성) / bge-m3(임베딩) / llama-guard3:1b(가드). 하드웨어 RTX 4050 6GB → vram_6gb 프로필.

2. 백엔드 구조도



설계 원칙 ① 검출과 집행 분리: 플러그인은 '의심'만 보고(recommended), 최종 차단/마스킹/격리는 Enforcer 한 곳이 결정 → 탐지 성능과 정책 효과를 따로 측정. ② 접근통제와 가드레일 분리: 역할/등급/소속 필터는 가드 모드와 무관하게 항상 fail-closed로 작동. 가드 OFF는 '내용 가드레일만' 끈다.

핵심 처리 흐름 (요청 1건):



fail-closed 권한 필터 · mock-sink 경계 · 유출 측정은 모든 가드 모드에서 항상 작동

※ 이 시스템은 도구를 실제 실행하는 에이전트가 아니다. '액션'은 [[ACTION:...]] 문자열을 파싱해 로컬 가짜 싱크로만 보내는 시뮬레이션이다.

3. 현재 진행 상태 (정직한 요약)

영역	상태	근거/비고
테스트 스위트	151개 전부 통과	mock 백엔드, GPU 불필요 (2026-11-01 실행)
수집 · 색인 · 권한검색 · 가드 훅 · 로깅	mock end-to-end 동작	rag.py / store.py / guards / metrics.py
라이브(Ollama) 실행	구현됨(미실행)	이번 리뷰에서 라이브 미실행 → '검증'으로 표기 안 함
공격 효능 지표(ASR/UPDR)	현재 N/A	검토된 공격 payload 0개 → 스키마가 집계 거부
실제 법령 코퍼스	미투입	현재 합성 문서만 색인

가장 중요한 공백: 모든 공격 문서가 [IPI_PAYLOAD_PLACEHOLDER]라 '활성 공격'이 아니다. 따라서 공격 차단율은 0%가 아니라 정직하게 N/A(측정 대상 없음)로 보고된다. 숫자가 나오려면 보안연구자의 검토 · 승인된 payload가 선행되어야 한다.

4. 역할별 할 일

● Legal (Role 1) — 법령 · 정책 데이터 제출

- 법령 → 가이드라인 → 내부정책 순으로, 원본 파일(.txt 권장/.pdf) + <document_id>.meta.json 사이드카로 제출
- 메타데이터 필수: document_id, document_version, source_name, source_type, source_trust_level, document_kind, pii_grade, tenant_id, allowed_roles (legislation/internal_policy는 law_or_policy_id도)
- 조문은 본문 머리말(예: 제15조)로 남기고, submission_index.csv에 검토 상태 기재. 템플릿 2종 제공됨
- 상세: docs/handoff/03_legal_data_submission.md (복붙용 요청문 포함)

● Security / Guardrail (Role 3) — 가드 로직 · 실험 · 공격 검토

- 가드 훅은 이미 연결됨 → 각 플러그인의 검출 로직/임계값만 채우면 됨 (GuardPlugin 프로토콜 준수)
- A/B/C/D를 guard_modes 그리드(OFF/단일/HYBRID)로 구성. 클린 케이스를 방어 켠 상태에서도 돌려 FPR · utility 측정
- egress 차단과 가드레일 차단을 섞지 말 것. 검색 실패 ≠ 모델 저항 (노출 계보 필드로 구분)
- [IPI_PAYLOAD_PLACEHOLDER]에 검토 · 승인된 템플릿 입력 후 review.status='reviewed'로 승인. 리뷰어/시각을 지어내지 말 것
- 상세: docs/handoff/04_guardrail_integration.md

● UI/UX · Metrics (Role 4) — 프런트 독립 설계

- 확정 엔드포인트 · QueryRequest/QueryResponse · 상태값(로딩/정상/근거없음/차단/권한거부/실패)으로 설계
- 일반 담당자 화면과 연구자(실험 · 정책 · 지표) 화면을 분리. 제한 문서 내용/비마스킹 PII 비노출
- 스트리밍 · 답변 내 인라인 출처는 미구현(제안) 전제. 근거는 retrieved[]의 preview_masked만 노출
- 상세: docs/handoff/05_uiux_backend_contract.md (JSON 예시 포함)

5. 주의할 점 (노트)

- 신뢰 경계: 검색된 문서 내용은 '신뢰 불가 증거'다. 문서 안의 지시/명령을 권한 있는 명령으로 취급하지 않는다. 이 분리가 얼마나 효과적인지가 바로 연구의 측정 대상(효과를 가정하지 않음).
- 정직한 결과 보고: 공격 지표는 숫자를 지어내지 않고 N/A로 둔다. 오류/타임아웃은 '방어 성공'으로 세지 않는다.

- '방어 없음(OFF)'의 정의: 내용 가드레일만 끈다. 인증 · 권한 필터 · 업로드 한도 · mock - sink 경계 · 유출 측정은 항상 켜져 있다. 권한 약화는 별도의 격리된 ablation에서만.
- egress 구조적 한계: 현재 후보 공격 목적지는 모두 미인가라 ALLOWLIST에선 실수신이 구조적으로 불가. 수신 0을 가드레일 효과로 읽으면 안 됨(실수신은 tool_egress=OPEN을 별도 요인으로).
- 인증 한계: 현재 공유 X - API - Key 1개 + 요청의 user_id는 신뢰 입력(역할 시뮬레이션). 다중 사용자 실로그인은 미구현.
- 안전: 합성 데이터 · 로컬 싱크만. 외부 목적지/실제 PII/셸 명령/새 실행능력 도입 금지. 목적지는 internal:// · mock - sink://만.
- 이번 핸드오프 백엔드 수정: ① GuardPolicy 기본 차단 카테고리에서 존재하지 않는 S14 제거(→[S7,S2]) ② Streamlit이 읽던 폐기 API 필드(ollama_reachable 등) 정정. 수정 후 151개 테스트 통과.